Acceptance Criteria — Frictionless Guest Checkout

Gherkin-style scenarios for the highest-risk stories. Treat these as the contract; deviation requires a refinement conversation.

US-04 / US-07 — Guest checkout, happy path

```
Feature: Guest checkout with card payment

  Background:
    Given the product catalogue is loaded
    And the cart contains 1 × "Premium Wireless Headphones" at $199.99

  Scenario: Successful guest checkout
    Given I am on the checkout page as a guest
    When I enter valid billing details, shipping address, and a valid test card
    And I click "Pay now"
    Then a Stripe payment intent is created
    And the payment succeeds
    And I am redirected to the confirmation page within 1 second
    And I see the order number
    And a payment.completed event is published to Kafka within 1 second
```

US-08 — Card validation on the client

```
Scenario: Client-side Luhn check catches a typo
  Given I am on the checkout page
  When I enter the card number "4242 4242 4242 4241"  # last digit wrong
  Then I see an inline error "Card number is invalid"
  And the "Pay now" button is disabled

Scenario: Valid test card passes the Luhn check
  Given I am on the checkout page
  When I enter the card number "4242 4242 4242 4242"
  Then no inline error is shown
  And the "Pay now" button is enabled
```

US-10 — Resilient retry on transient failures

```
Scenario: Retry succeeds within the backoff budget
  Given Stripe returns "network_error" on the first attempt
  And Stripe returns success on the second attempt
  When the user submits payment
  Then the system retries once after the initial backoff
  And the user sees the success page
```

```
  And the user does not see any retry indicator

Scenario: Permanent failure is not retried
  Given Stripe returns "card_declined"
  When the user submits payment
  Then no retry is attempted
  And the user sees "Card was declined" inline on the form
```

US-11 — Per-IP rate limiting

```
Scenario: 11th payment attempt in a minute is rejected
  Given 10 successful POSTs to /api/create-payment-intent from IP 203.0.113.7 in the last minute
  When an 11th POST arrives from the same IP within the same minute
  Then the response status is 429
  And the response body is {"error": "rate_limit_exceeded"}
```

US-05 / US-12 — Confirmation email and downstream event

```
Scenario: Email and event on successful payment
  When the payment succeeds for order ORD-12345
  Then SendGrid is called with template "order_confirmation"
  And the email contains the order number, line items, and grand total
  And a payment.completed event is published to Kafka topic "orders"
  And the event payload contains orderId, total, currency, and items[]
```

Non-functional acceptance

- **Performance:** p95 of the /api/create-payment-intent round trip (excluding Stripe) is ≤ 200ms under nominal load.
- **Accessibility:** the checkout form passes WCAG 2.2 AA — every input has a programmatic label, error messages are announced to screen readers via aria-live, focus does not get trapped, and contrast ratio ≥ 4.5:1.
- **Security:** no card PAN ever leaves the Stripe iframe; server logs must never contain card numbers, CVVs, or full IBANs.
- **Idempotency:** repeated submission of the same payment intent ID must not result in a double charge.

Open questions (flag during refinement)

These are deliberately unresolved — surface them during refinement:

1. What is the exact behaviour when SendGrid is down? Queue, retry, or drop?

2. The Epic says “all customer PII deleted within 30 days” but order records are retained 7 years for tax — what counts as PII vs. order data, and how do we square that with GDPR right-to-erasure?
3. What is the behaviour when the user closes the tab between payment intent creation and confirmation?
4. Does the Kafka publish need to be transactional with the payment confirmation, or is at-least-once with deduplication downstream acceptable?
5. What happens to a guest cart after 24 hours of inactivity?